Amazon Web Services: Security

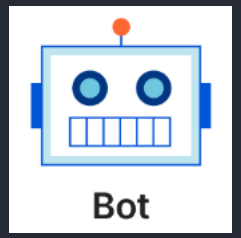
Topics

- DDoS
- Logging API Calls with Cloud Trail
- Protecting Applications with Shield
- Filtering Traffic With AWS WAF
- Guard Network with Guard Duty
- Monitoring S3 Buckets with Macie
- Securing Operating Systems

Topics

- Managing Encryption Keys KMS and CloudHMS
- Storing Your Secrets in Secrets Manager
- Storing Your Secrets in Parameter Store
- Temporarily Sharing S3 Objects Using Presigned URLs or Cookies
- AWS Certificate Manager
- Authenticating Access with Amazon Cognito
- Protecting VPCs with AWS Network Firewall

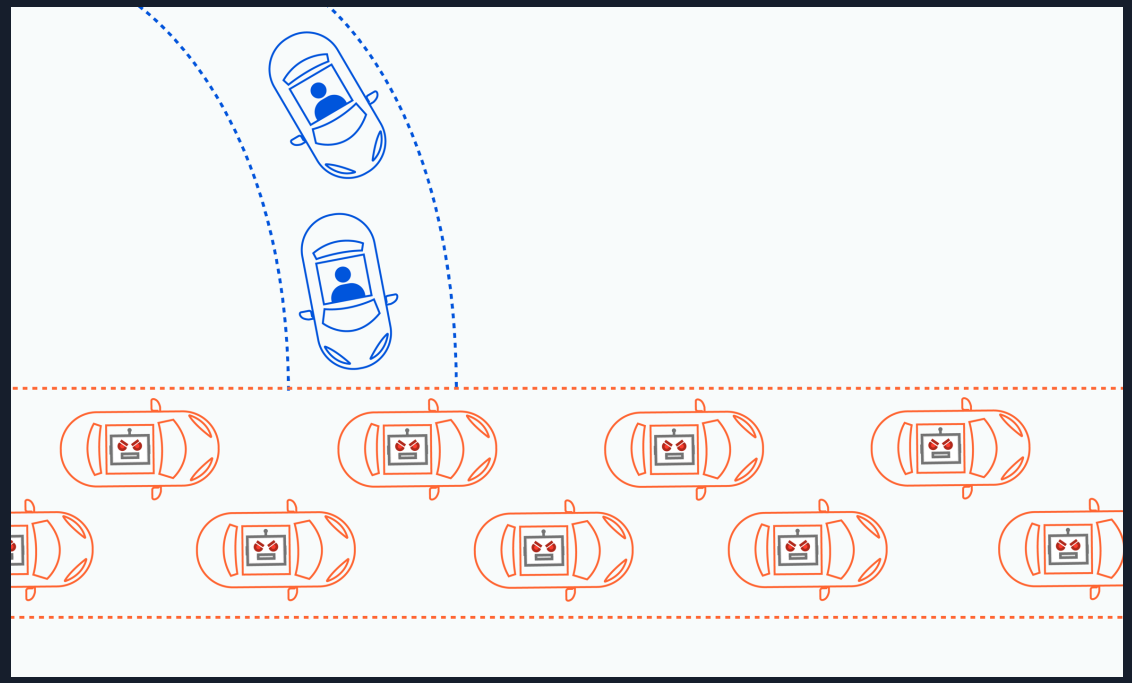
DDoS



What is a DDoS Attack?

- A Distributed Denial of Service (DDoS) attack is an attack that attempts to make your website or application unavailable to your end users

- This can be achieved by multiple mechanisms, such as large packet floods, by using a combination of reflection and amplification techniques, or by using large botnets



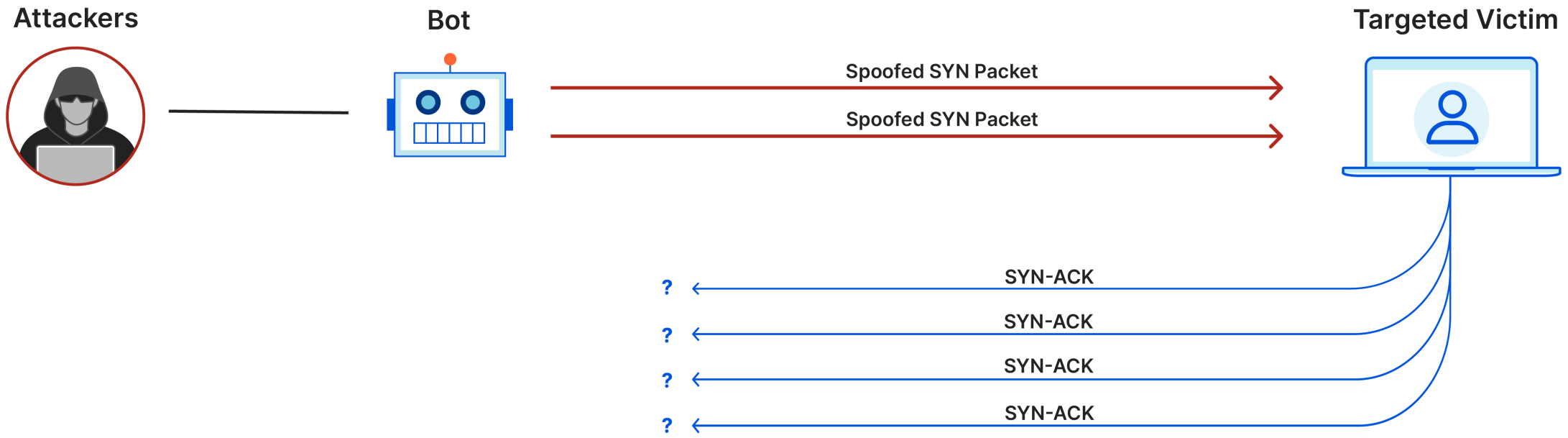
https://www.cloudflare.com/learning/ddos/what-is-a-ddos-attack/

What is a Layer 4 DDoS Attack?

- A Layer 4 DDoS attack is often referred to as a SYN flood
- It works at the transport layer (TCP)
- To establish a TCP connection a 3-way handshake takes place

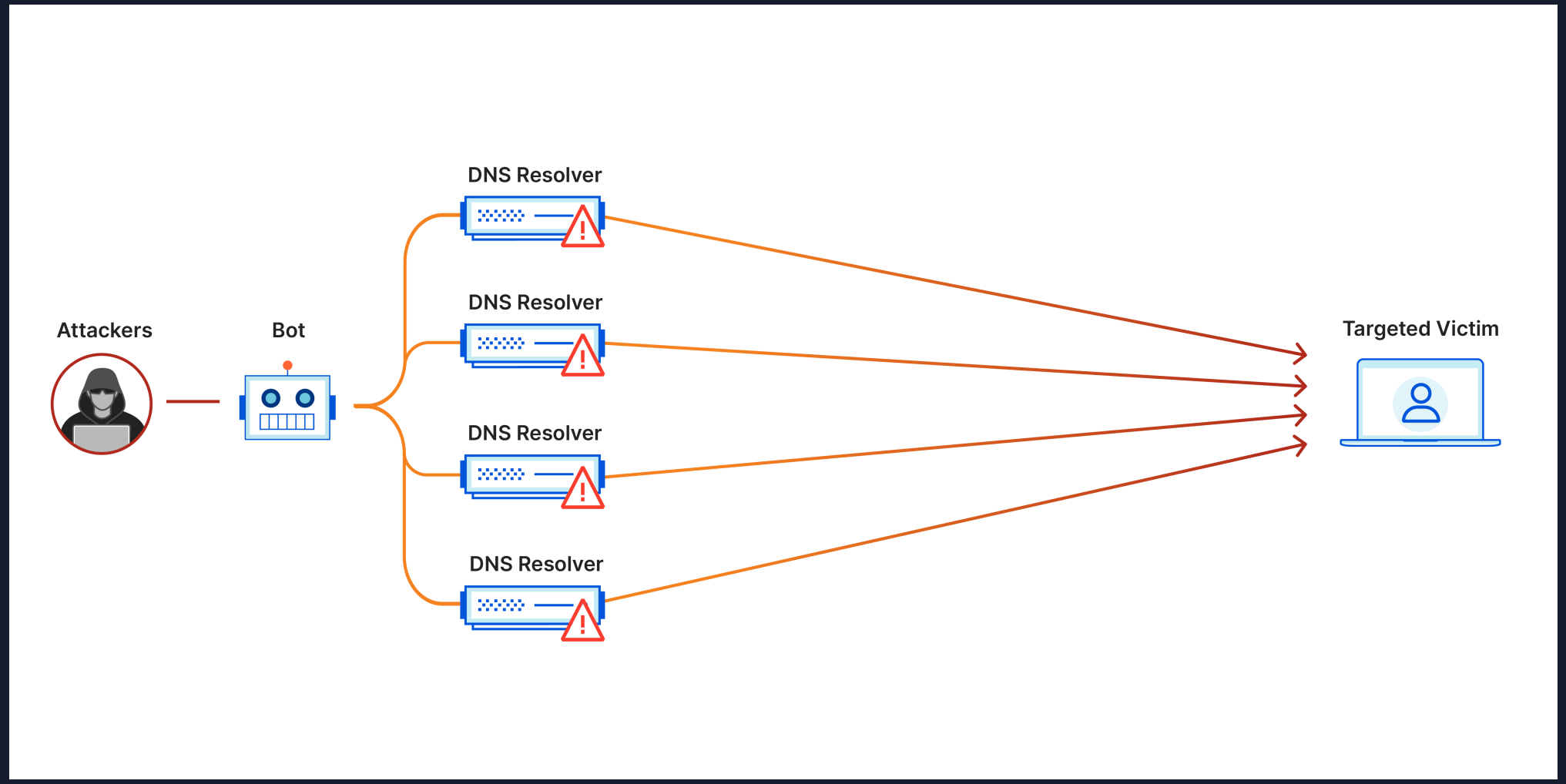
1. The client sends a SYN packet to a server
2. The server replies with a SYN-ACK, and
3. The client then responds to that with an ACK
4. TCP connection is established
5. Application sends data using Layer 7

SYN Floods



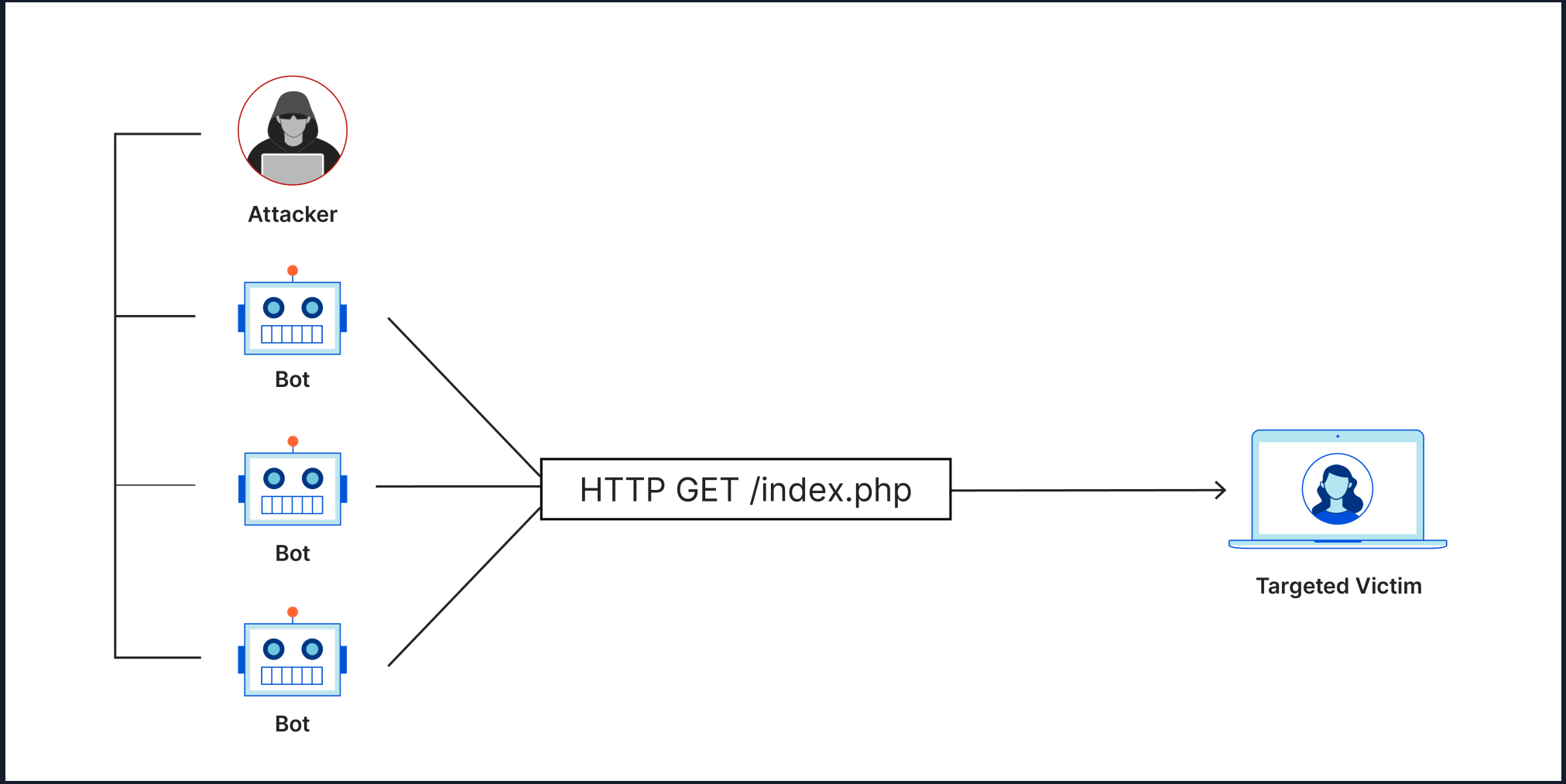
https://www.cloudflare.com/learning/ddos/what-is-a-ddos-attack/

Amplification Attack



https://www.cloudflare.com/learning/ddos/what-is-a-ddos-attack/

Layer 7 Attack

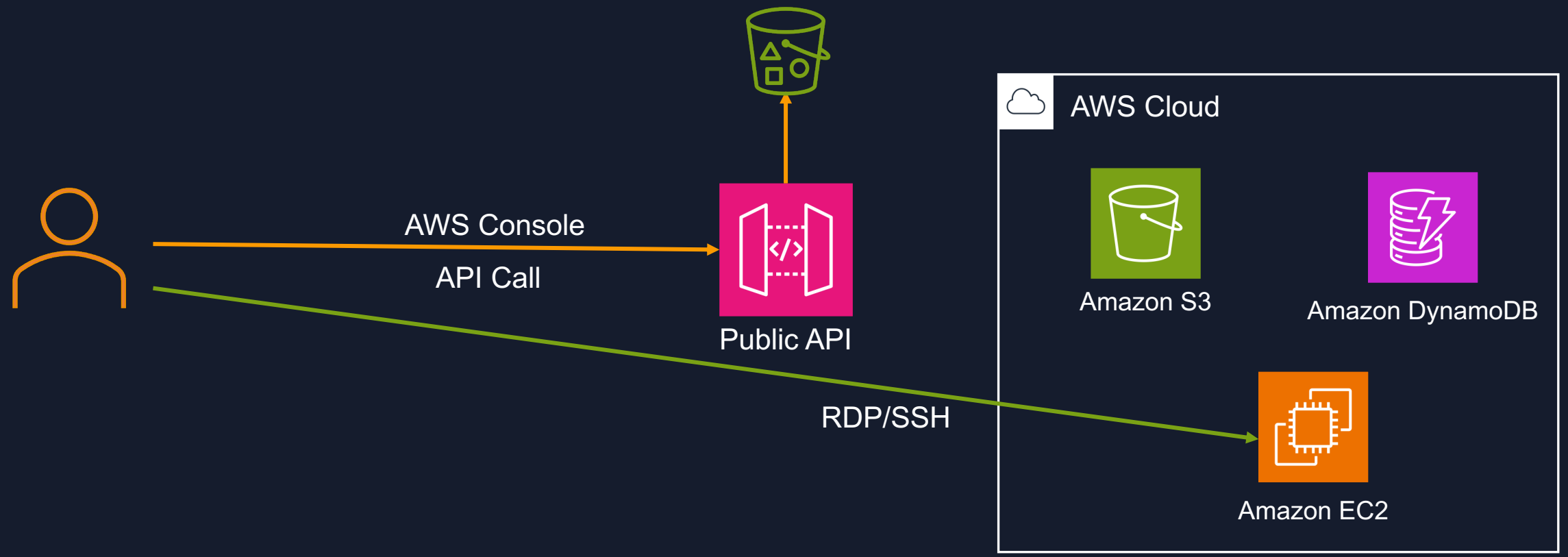


https://www.cloudflare.com/learning/ddos/what-is-a-ddos-attack/

Logging API Calls with Cloud Trail

What is CloudTrail?

- AWS CloudTrail increases visibility into your user and resource activity by recording AWS Management Console actions and API calls



What is CloudTrail?

What is logged?

- Metadata around API calls
- The identity of the API caller
- The time of the API call
- The source IP address of the API caller
- The request parameters
- The response elements returned by the service

What CloudTrail Allows

- After-the-fact incident investigation
- Near real-time intrusion detection
- Industry and regulatory compliance

Protecting Applications with AWS Shield

What is AWS Shield?

- Free DDoS protection
- Protects all AWS customers on Elastic Load Balancing (ELB), Amazon CloudFront, and Route 53
- Protects against SYN/UDP floods, reflection attacks, and other Layer 3 and Layer 4 attacks

What is Shield Advanced?

- Provides enhanced protections
- Offers always-on, flow-based monitoring
- Gives 24/7 access to the DDoS Response Team (DRT)
- Protects AWS bill

AWS Shield Advanced

Filtering Traffic With AWS WAF

What is AWS WAF?

- AWS WAF is a web application firewall
- Allows you to monitor the HTTP and HTTPS requests that are forwarded to Amazon CloudFront or an Application Load Balancer
- Can configure conditions such as what IP addresses are allowed to make this request or what query string parameters need to be passed for the request to be allowed
- The Application Load Balancer or CloudFront will either allow this content to be received or give an HTTP 403 status code
- Operates at Layer 7

AWS WAF Behaviors

- **Allow all requests** except the ones you specify
- **Block all requests** except the ones you specify
- **Count the requests** that match the properties you specify
- You can define conditions by using characteristics of web requests such as the following:

1. IP addresses that requests originate from
2. Countries that requests originate from
3. Values in request headers
4. Presence of SQL code that is likely to be malicious
5. Presence of a script that is likely to be malicious
6. Strings that appear in requests

Guard Network with GuardDuty

What is GuardDuty?

- Threat detection service
- Uses Machine Learning to continuously monitor for malicious behavior
  - Unusual API calls
  - Attempts to disable CloudTrail logging
  - Unauthorized deployments
  - Compromised instances
  - Port scanning
  - Failed logins

GuardDuty Features

- Alerts appear in the GuardDuty console and CloudWatch Events
- Receives feeds from third parties and from AWS Security about know malicious domain and IP addresses
- Monitors CloudTrail logs, VPC Flow Logs, and DNS logs
- Centralized threat detection across multiple AWS accounts
- Automated responses built in using CloudWatch Events and Lambda
- Machine learning and anomaly detection

Monitoring S3 Buckets with Macie

What is PII?

- Personal data used to establish an individual’s identity
- This data could be exploited by criminals, used in identity theft and financial fraud
- Home address, email address, Social Security number
- Passport number, driver’s license number
- Date of birth, phone number, bank account, credit card number

What is Macie?

- Automated analysis of data
- Uses machine learning and pattern matching to discover sensitive data stored in S3
- Uses AI to recognize if your S3 objects contain sensitive data, such as PII, PHI, and financial data
- Alerts you to unencrypted buckets Alerts you about public buckets
- Can also alert you about buckets shared with AWS accounts outside of those defined in your AWS organizations
- Great for frameworks like HIPAA and GDPR

Macie Alerts

- You can filter and search Macie alerts in the AWS console
- Alerts sent to Amazon EventBridge can be integrated with your security incident and event management (SIEM) system
- Can be integrated with AWS Security Hub for a broader analysis of your organization's security posture
- Can also be integrated with other AWS services, such as Step Functions, to automatically take remediation actions

Securing Operating Systems with Inspector

What is Amazon Inspector?

- Automated security assessment service that helps improve the security and compliance of applications deployed on AWS
- Automatically assesses applications for vulnerabilities or deviations from best practices
- Assessment Findings

2 Types of Assessment

Network Assessments

- Network configuration analysis to checks for ports reachable from outside the VPC
- Inspector agent is not required

Host Assessments

- Vulnerable software (CVE, host hardening (CIS Benchmarks), and security best practices
- Inspector agent is required

Managing Encryption Keys KMS and CloudHMS

What is AWS KMS?

- AWS Key Management Service (KMS) is a managed service that makes it easy for you to create and control the encryption keys used to encrypt your data
- Integrated with other AWS services such as EBS, S3, and RDS, as well as other services to make it simple to encrypt your data with encryption keys you manage
- Provides you with over the lifecycle and permissions of your keys. You can create new keys whenever you wish, and you can control who can manage keys separately from who can use them

Customer Master Key (CMK)

- Logical representation of a master key
- Includes metadata such as Key ID, creation date, description, and key state
- Contains the key material used to encrypt and decrypt data
- Getting started: You start using the service by requesting the creation of a CMK. You control the lifecycle of the CMK as well as who can use or manage

3 Ways to Generate a CMK

1

AWS creates the CMK for you. The key material for a CMK is generated within HSMs managed by AWS KMS.

2

Import key material from your own key management infrastructure and associate it with a CMK.

3

Have the key material generated and used in an AWS CloudHSM cluster as part of the custom key store feature in AWS KMS.

Key Rotation

- You can choose to have AWS KMS automatically rotate CMKs every year, provided that those keys were generated within AWS KMS HSMs

- Automatic key rotation is not supported for imported keys, asymmetric keys, or keys generated in an AWS CloudHSM cluster using the AWS KMS custom key store feature

Key Policies

- The primary way to manage access to your AWS KMS CMKs is with policies
- Policies are documents that describe who has access to what
- Policies attached to an IAM identity are called identity- based policies (or IAM policies), and policies attached to other kinds of resources are called resource-based policies
- In AWS KMS, you must attach resource-based policies to your customer master keys (CMKs)
- These are called key policies
- All KMS CMKs have a key policy

3 Ways to Control Permissions

1

Use the key policy

Controlling access this way means the full scope of access to the CMK is defined in a single document (the key policy)

2

Use IAM policies in combination with the key policy

Controlling access this way enables you to manage all the permissions for your IAM identities in IAM

3

Use grants in combination with the key policy

Controlling access this way enables you to allow access to the CMK in the key policy, as well as allow users to delegate their access to others

CloudHSM

- Enables you to easily generate and use your own encryption keys on the AWS Cloud

KMS

- Shared tenancy of underlying hardware
- Automatic key rotation
- Automatic key generation

VS

CloudHSM

- Dedicated HSM
- Full control of underlying hardware
- Full control of users, groups, keys, etc.
- No automatic key rotation

Storing Your Secrets in Secrets Manager

What is Secrets Manager?

- Secrets Manager is a service that securely stores, encrypts, and rotates your database credentials and other secrets
- Encryption in transit and at rest using KMS
- Automatically rotates credentials
- Apply fine-grained access control using IAM policies • Costs money but is highly scalable

Secrets Manager

What else can Secrets Manager do?

- Your application makes an API call to Secrets Manager to retrieve the secret programmatically
- Reduces the risk of credentials being compromised

What can be stored?

- RDS credentials
- Credentials for non-RDS databases
- Any other type of secret, provided you can store it as a key-value pair (SSH keys, API keys)

Automatic Rotation

- If you enable rotation, Secrets Manager immediately rotates the secret once to test the configuration
- **Disable Rotation**
- If your applications are still using embedded credentials, do not enable rotation because this will break your application
- **Enable Rotation**
- This is the recommended setting if your applications are not already using embedded credentials

Storing Your Secrets in Parameter Store

What is Parameter Store?

- Parameter Store is a capability of AWS Systems Manager that provides secure, hierarchical storage for configuration data management and secrets management
- It is free
- Limitations:
  - Limit to the number of parameters you can store
  - No key rotation

Temporarily Sharing S3 Objects Using Presigned URLs or Cookies

Privacy

- All objects in S3 are private by default
- Only the object owner has permission to access these objects
- However, the object owner can optionally share objects with others by creating a Presigned URL using their own security credentials, to grant time-limited permission to download the objects

Presigned URLs and Presigned Cookies

Presigned URLs	Presigned Cookies
• Must provide security credentials, specify a bucket name and an object key, and indicate the HTTP method as well as expiration date and time • Anyone who receives the presigned URL can then access the object	• Useful when you want to provide access to multiple restricted files • The cookie will be saved on the user's computer, and they will be able to browse the the entire contents of the restricted content

AWS Certificate Manager

What is AWS Certificate Manager?

- Allows you to create, manage, and deploy public and private SSL certificates for use with other AWS services

- It integrates with other services allowing you to easily manage and deploy SSL certificates in your AWS environment

Benefits of AWS Certificate Manager

1

Cost

No more paying for SSL certificates

2

Automated Renewals and Deployments

Automates the renewal of SSL certificates

3

Easier to Set Up

Removes a lot of the manual process

Authenticating Access with Amazon Cognito

What is Cognito?

- Provides authentication, authorization, and user management for web and mobile apps in a single service without the need for custom code

- Users can sign in directly with a username and password they create or through a third party (e.g., Facebook, Amazon, Google, or Apple)

Features

- Sign-up and sign-in options for your apps
- Access for guest users
- Acts as an identity broker between your application and web ID providers, so you don’t need to write any custom code
- Synchronizes user data across multiple devices
- Recommended for all mobile applications that call AWS services

Use Cases

Authentication

- Users can sign in using a user pool or a third-party identity provider, such as Facebook

Access Server-Side Resources

- A signed-in user is given a token that allows them access to resources that you specify

Third-Party Authentication

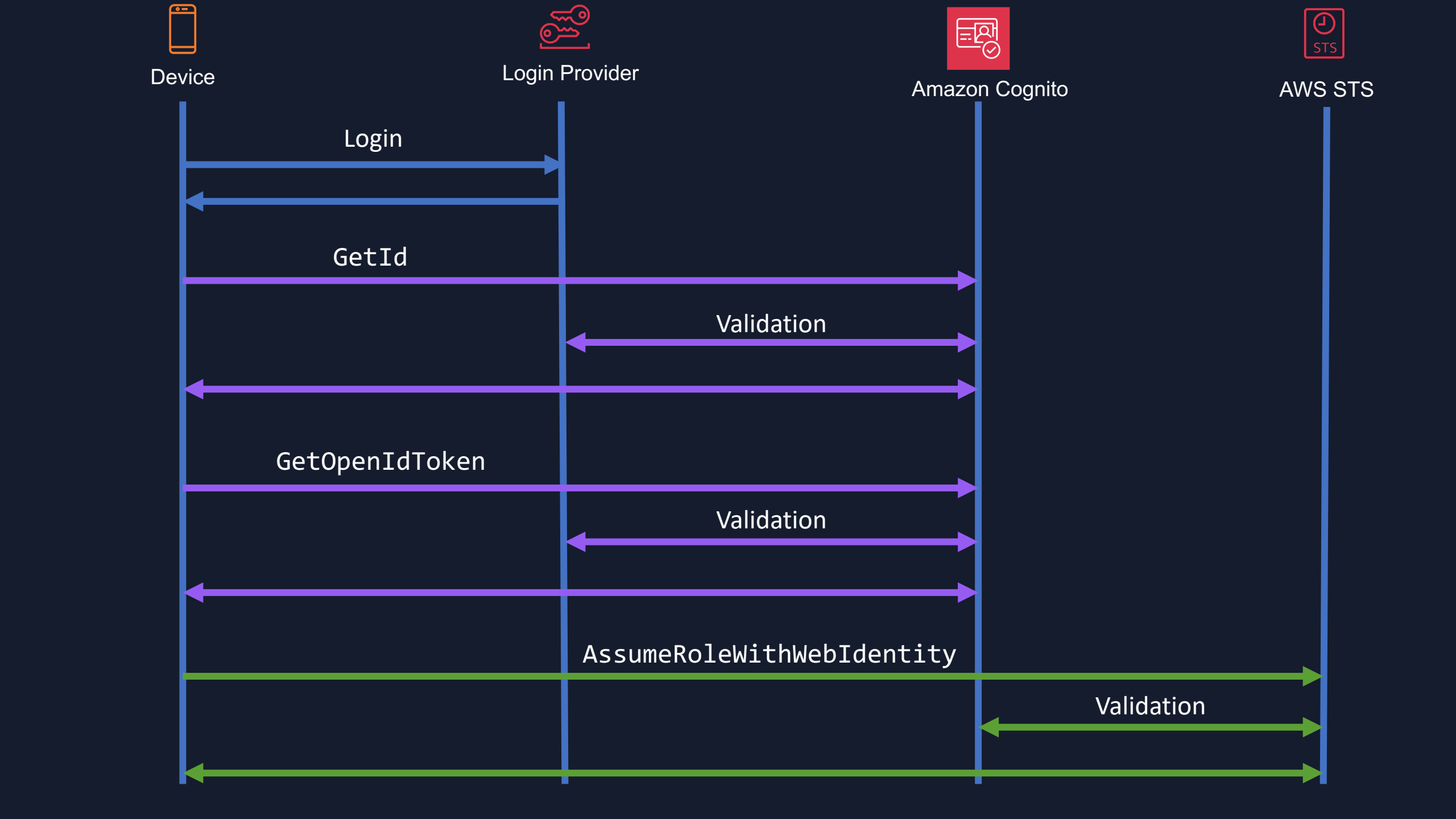
- Users can authenticate using identity pools that require an identity provider (IdP) token

Access AWS AppSync Resources

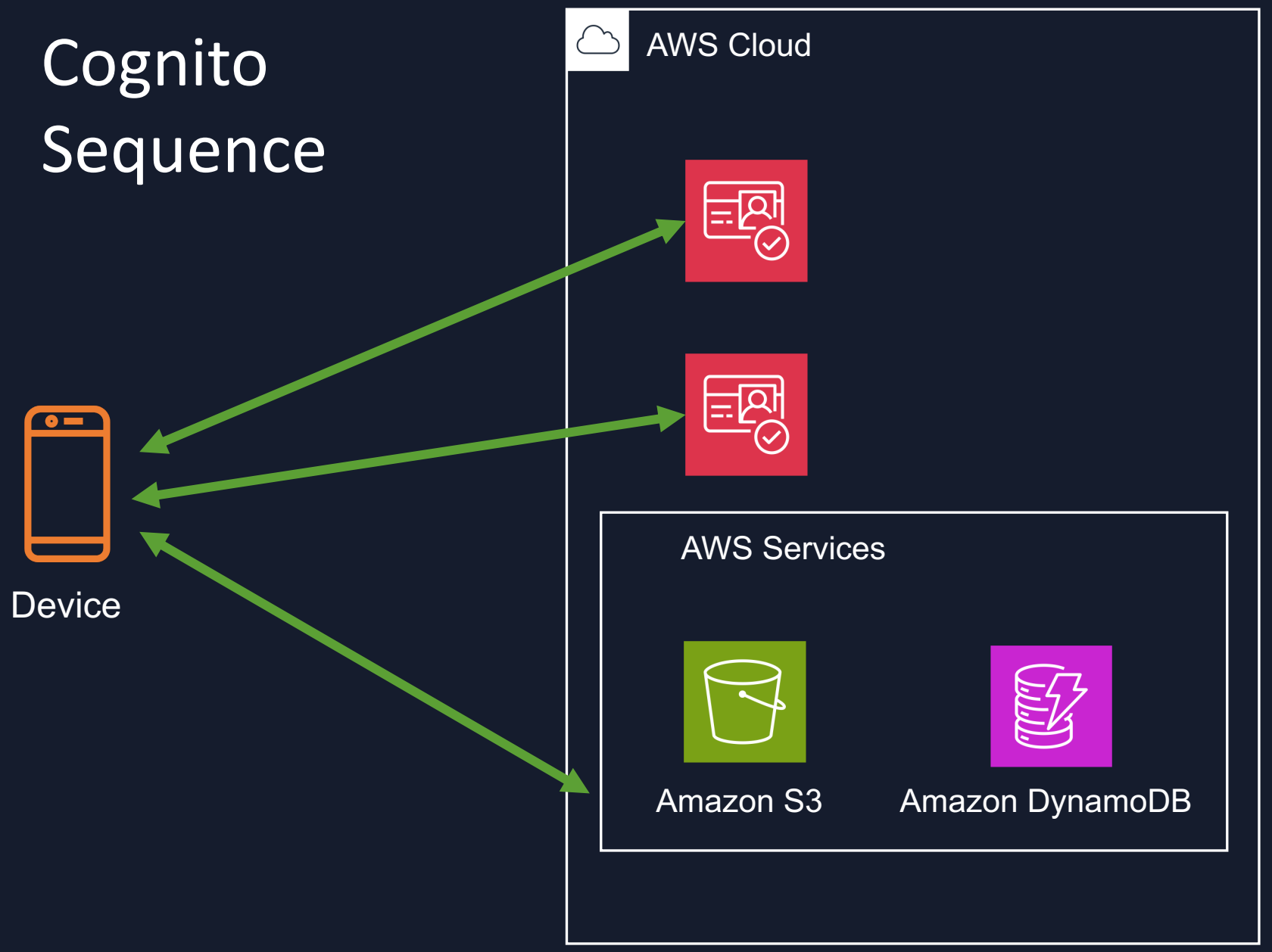
- Users can be given access to AppSync resources with tokens received from a user or identity pool in Cognito

User Pools and Identity Pools

User Pools	Identity Pools
• Are directories of users that provide sign-up and sign-in options for application users	• Allow you to give users access to other AWS services


Device
Login Provider
Amazon Cognito
AWS STS
Login
GetId
Validation
GetOpenIdToken
Validation
AssumeRoleWithWebIdentity
Validation

Cognito Sequence



1. Authenticate and get tokens

2. Exchange tokens and get AWS credentials

3. Access AWS services using credentials

Protecting VPCs with AWS Network Firewall

What is AWS Network Firewall?

- Managed service that makes it easy to deploy physical firewall protection across your VPCs.
- It has a managed infrastructure (i.e., a physical firewall that is managed by AWS)
- Network Firewall includes a firewall rules engine that gives you complete control over your network traffic, allowing you to do things such as block outbound Server Message Block (SMB) requests to stop the spread of malicious activity

Benefits of Network Firewall

- Network Firewall has physical infrastructure in the AWS datacenter that is managed by AWS staff — so you don’t need to worry about management overheads
- Works with AWS Firewall Manager to centrally manage security policies across existing and newly created accounts and VPCs
- Provides intrusion prevention system (IPS) that gives you active traffic flow inspection

Use Cases

Filter Internet Traffic

- Use methods like ACL rules, stateful inspection, protocol detection, and intrusion prevention to filter internet traffic

Filter Outbound Traffic

- Use a network firewall to provide the URL/domain name, IP address, and content-based outbound traffic filtering to stop possible data loss and block unknown malware communications

Inspect VPC-to-VPC Traffic

- You can automatically inspect traffic moving from one VPC to another as well as across multiple accounts

Checkpoint

What kind of data can Macie identify?

1. Social security numbers
2. Personal identifiable information (PII) such as names and addresses
3. Credit card numbers
4. All of the other answers

You need a managed service that makes it easy to deploy physical firewall protection across your VPCs. Which service should you use?

1. AWS Firewall Manager
2. AWS Audit Manager
3. Amazon Cognito
4. AWS Network Firewall

In general, what does a DDoS attack entail?

1. A large number of connections overwhelms your architecture. Your application is unable to answer the legitimate requests that are sent to it.
2. A small number of users have connected to your backend database. These connections lead to a denial of requests being sent through.
3. Your local users left too many computers running in the data center. This has drawn too much power and starts to cause rolling outages in your compute platform.
4. AWS is unable to handle the scale of traffic that it is receiving. This causes your EC2 instances to go offline.

You need a security management service in a single pane of glass to manage your firewalls. Which service should you use?

1. AWS Network Firewall
2. Amazon Detective
3. AWS Firewall Manager
4. AWS Artifact

Your boss requires automatic key rotation for your encrypted data. Which AWS service supports this?

1. EBS
2. SQS
3. EC2
4. KMS

What kind of findings can AWS Inspector discover?

1. The AWS root account not being properly secured.
2. Insufficient patching of applications on an EC2 instance.
3. Users having too many permissions in your AWS account.
4. Running the wrong OS (using Windows when you should be using Linux, etc).

Where is the most cost effective place to store your database passwords in a secure manner?

1. Parameter Store
2. S3
3. EBS
4. Secrets Manager

Amazon Web Services: Security